# Mumba Chitonge

## Backend kickoff | Virtual Ink

Technical Lead - Shadow Root Security Technologies - 9 October 2026

**Start here:** finish genuine Auth-to-API verification of the existing foundation. Preserve the current schema and restricted service accounts before preparing membership lifecycle changes.

### What you are inheriting

| Area | Latest recorded state |
|---|---|
| Backend | Node.js 24, shared TypeScript, npm, independent HTTP adapter |
| Web | Next.js/React source; shared server handlers; TypeScript passes |
| Database | Supabase development, nine private tables, eight Phase 2 migrations |
| Protected reads | /api/v1/me; /api/v1/tenants/:tenantId/access; /api/v1/memberships |
| Evidence | 90 tests pass; hosted isolation/audit assertions pass |
| Still open | Genuine Auth/pg/TLS, owned PostgreSQL replay, review/signoff |

Both database service accounts remain NOLOGIN. Auth and application tables were empty after rolled-back tests. This snapshot is local work: confirm the shared checkout contains the latest membership code and migrations before starting. It does not establish production readiness.

### Read in this order

- README.md and AGENTS.md: working agreement, current scope and reporting.
- docs/source-document-baseline.md: supplied PDFs mapped to delivered and missing work.
- docs/live-backend-setup.md and docs/trusted-provisioning.md: private setup and approved onboarding.
- docs/membership-discovery.md, docs/permissions-plan.md and docs/open-questions.md: current contract, exclusions and decisions.

### Code entry points

Use src/backend/identity/ for identity, memberships and routes; src/backend/database/ for runtime, readiness and transaction reset. Review database/phase2/, supabase/migrations/, test/memberships.test.ts and database/tests/membership-discovery.sql together.

**PDF references:** Backend Phase 2 Build Plan sections 4-9; Security Architecture and Flow sections 3-6. Viewer page numbers include the cover. Escrow is a later simulation gate.

# First work session

## 1. Reproduce the baseline

Commands below run from your Virtual Ink checkout. This example path is the current workstation; adjust it on your machine.

```
Set-Location D:\Work\Projects\virtual-ink
node --version
npm test
npm run typecheck:web
npm run setup:init
npm run setup:check
```

Use Node 24. setup:init preserves existing settings. Record actual results; the historical 90-pass result does not replace your run. Do not reapply hosted migrations to the existing development project.

## 2. Complete private runtime setup

- Install/pin pg with legitimate registry access: npm install --save-exact pg. Preserve and review the actual root lockfile.
- Use the correct project connection settings and trusted CA from the approved dashboard. Keep API credentials in root .env and provisioner credentials in .private/provisioning.env; Next server settings use apps/web/.env.local.
- Follow the live setup guide for private password prompts and reviewed LOGIN activation. Do not grant ownership, bypass RLS or administrator membership to either runtime account.
- Obtain Uchi's approved development identity/onboarding references and Lubasi's verified owner/staff facts. Tokens go through bounded stdin or approved private tooling, never command arguments, screenshots or reports.

## 3. Prove real behavior

```
npm run setup:check -- --database
npm start
```

Health is at http://127.0.0.1:3000/health. Without a bearer, the membership route returns 401; this proves routing only. Passing readiness is not a successful login.

Use npm run test:auth:live with a genuine token via stdin as documented. Its five checks cover current-user/tenant behavior; separately verify membership discovery and committed membership_list_audits with an approved administrator. Do not give API accounts audit-read rights to inspect evidence.

**Exit evidence:** genuine identity, own scope allowed, other scope denied, active-only memberships, audit committed, no secrets in output. If setup is incomplete, record the named blocker and keep the runtime disabled.

# Next slice and handover

## Prepare one audited suspension workflow

After genuine verification and Uchi's decisions, prepare membership suspension as the next small slice. Create/invite, reactivation, ownership transfer and unrestricted audit review are separate work. Current API credentials cannot mutate memberships.

- Resolve MEMBER-01/02/03: authority, last-owner protection and the membership-list contract.
- Resolve AUTH-01/02: session revocation and what deactivation guarantees for requests already in flight. Existing transaction snapshots can remain valid until the transaction ends.
- Review SEC-01 and AUDIT-01/02: abuse limits/MFA, denial records and purpose-bound audit review.
- Write criteria, migration/grant changes, rollback or forward-correction notes and tests before exposing the workflow.

## Non-negotiable implementation checks

- Derive identity, tenant and permission on the server. Client vendor_id, role or totals are never authority.
- Prove wrong-role, inactive, guessed-ID and cross-tenant denial; test audit/commit failure and pool context reset.
- Keep customer files/proofs private. Delivery partners receive neither files/proofs nor payment details.
- Keep Supabase adapters separate and application SQL portable. Rehearse all eight migrations on an isolated owned PostgreSQL 17 target; do not touch an unrelated local database.
- Leave payments, checkout, uploads, live tracking, printer automation and production deployment outside this slice.

## What to hand back

Give Uchi the acceptance record, changed files, actual commands/test results, redacted audit evidence, unresolved decisions and recovery notes. Give Taizya the exact API fields and allowed empty/error/session states. Give Lubasi the operational questions needing verified facts. Update the task board and create dated Markdown and Word team reports.

## Copy-ready next prompt

```
Continue Virtual Ink as Technical Lead. Read the supplied-document
baseline and live setup guide. Verify genuine Auth/pg/TLS and the
existing protected reads, including memberships and committed audits.
Keep secrets out of logs and reports. Review Uchi's authority and
revocation decisions, then prepare one audited membership-suspension
slice with last-owner protection and cross-tenant denial tests.
Keep marketplace, uploads and escrow outside this slice. Report
actual evidence and remaining blockers in Markdown and Word.
```

**Acceptance:** Mumba provides technical evidence; Uchi records the product decision. This guide does not sign off on anyone's behalf.